

CỘNG HOÀ XÃ HỘI CHỦ NGHĨA VIỆT NAM

Độc lập – Tự do – Hạnh phúc

THUYẾT MINH SÁNG KIẾN

SecureVault Mobile — Ứng dụng bảo vệ dữ liệu nhạy cảm trên thiết bị Android, hoạt động hoàn toàn ngoại tuyến, phục vụ công tác và huấn luyện an toàn thông tin

MỤC LỤC

Nhấn chuột phải vào đây rồi chọn “Cập nhật trường” để hiện mục lục.

TÓM TẮT SÁNG KIẾN

Vấn đề. Điện thoại đã trở thành nơi lưu và trao đổi nhiều dữ liệu nội bộ phát sinh trong công tác và huấn luyện. Các biện pháp sẵn có hoặc chỉ bảo vệ khi máy tắt, hoặc là phần mềm mã nguồn đóng không kiểm chứng được, hoặc là công cụ mạnh nhưng không có bản dùng được trên di động.

Nguyên nhân kỹ thuật của khoảng trống. Các công cụ mật mã tin cậy phần lớn ở dạng tệp nhị phân chạy độc lập. Hệ điều hành di động không cho ứng dụng sinh tiến trình con để chạy chúng, nên không thể chuyển thẳng sang điện thoại. Đây là rào cản thực sự, không phải vấn đề công sức lập trình.

Giải pháp. SecureVault Mobile đặt một điểm nổi trù tượng tại vị trí bộ mã hoá nội dung, cho phép thay bộ mã hoá dạng tiến trình con bằng bộ mã hoá chạy trong tiến trình ứng dụng mà không làm thay đổi định dạng tệp. Toàn bộ nghiệp vụ mật mã nằm trong một lõi dùng chung; phần khác biệt giữa các nền tảng được cô lập và trình biên dịch tự chọn.

Bằng chứng. Tính tương thích định dạng được kiểm chứng bằng thực nghiệm đối chứng hai chiều với công cụ chuẩn, không phải bằng suy luận. Sản phẩm có 38 lệnh nghiệp vụ, 267 hàm kiểm thử tự động, đã biên dịch và chạy được lõi trên kiến trúc ARM64, và đã đóng gói thành tệp cài đặt Android (APK) có kiểm tra tĩnh kèm theo.

Giá trị. Sản phẩm vừa dùng được trong công tác để bảo vệ dữ liệu ngay trên thiết bị, vừa là học cụ trực quan cho giảng dạy an toàn thông tin: mỗi chức năng tương ứng một nguyên lý trong chương trình, và mã nguồn mở cho phép học viên đọc, chạy lại và phân tích.

Giới hạn được nêu rõ. Sản phẩm chưa được kiểm thử trên điện thoại Android thật tại thời điểm lập hồ sơ; quy trình để tự kiểm chứng được cung cấp tại Phụ lục A. Hồ sơ không đưa ra tuyên bố nào về việc sản phẩm được phép xử lý tài liệu thuộc danh mục bí mật nhà nước.

A. THÔNG TIN CHUNG

Bảng 1. Thông tin chung về sáng kiến

Nội dung	Thông tin
Tên sáng kiến	SecureVault Mobile — Ứng dụng bảo vệ dữ liệu nhạy cảm trên thiết bị Android, hoạt động hoàn toàn ngoại tuyến
Lĩnh vực áp dụng	An toàn thông tin trên không gian mạng; bảo vệ dữ liệu trên thiết bị di động; đào tạo – huấn luyện
Tác giả	
Đơn vị công tác	
Thời gian thực hiện	
Hình thức sản phẩm	Phần mềm ứng dụng Android (tệp APK) kèm mã nguồn, tài liệu kiến trúc và bộ kiểm thử tự động

B. NỘI DUNG CHÍNH CỦA SÁNG KIẾN

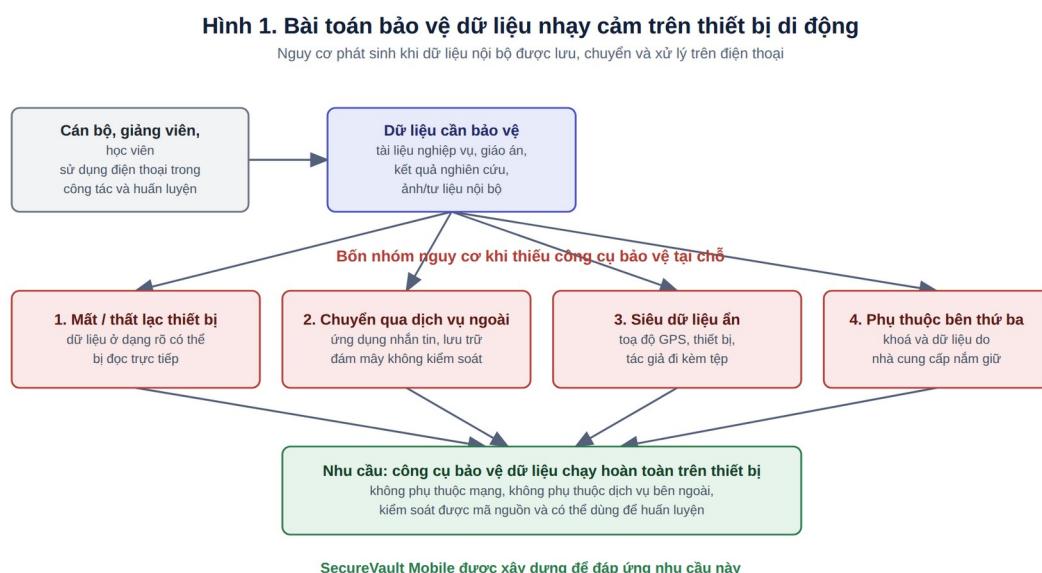
1. Hiện trạng giải pháp đã biết

1.1. Bối cảnh và nhu cầu thực tiễn

Điện thoại thông minh hiện là công cụ làm việc thường xuyên của cán bộ, giảng viên và học viên. Tính cơ động của thiết bị mang lại hiệu quả rõ rệt trong công tác, giảng dạy và nghiên cứu, nhưng đồng thời làm thay đổi căn bản phạm vi tồn tại của dữ liệu: nhiều tài liệu trước đây chỉ nằm trong máy tính cố định nay được sao chép, xem và trao đổi ngay trên thiết bị cá nhân.

Trong quá trình công tác và huấn luyện an toàn thông tin, thực tế phát sinh nhiều loại dữ liệu cần được bảo vệ ở mức cao hơn dữ liệu thông thường: giáo án và tài liệu biên soạn nội bộ, đề bài và đáp án các bài thực hành, kết quả nghiên cứu chưa công bố, ảnh và tư liệu phục vụ huấn luyện, dữ liệu trao đổi nghiệp vụ giữa các bộ phận. Đây là những dữ liệu mà việc lộ, lọt tuy không nhất thiết cấu thành sự cố ở mức cao nhất nhưng vẫn gây ảnh hưởng đến chất lượng công tác, tính khách quan trong đánh giá và uy tín của đơn vị.

Bốn nhóm nguy cơ nổi bật khi loại dữ liệu này tồn tại trên thiết bị di động mà thiếu công cụ bảo vệ tại chỗ được trình bày ở Hình 1.



Hình 1. Bài toán bảo vệ dữ liệu nhạy cảm trên thiết bị di động

1.2. Các nhóm giải pháp đã biết và hạn chế

Tác giả đã khảo sát các nhóm giải pháp hiện có theo hướng tiếp cận chức năng, nhằm xác định chính xác khoảng trống mà sáng kiến cần lấp. Việc phân tích dưới đây là khách quan, không nhằm phủ nhận giá trị của các giải pháp đã biết — mỗi nhóm đều giải quyết tốt bài toán mà nó được thiết kế cho.

Bảng 2. So sánh các nhóm giải pháp đã biết với nhu cầu đặt ra

Nhóm giải pháp	Giải quyết tốt	Hạn chế đối với bài toán đang xét
Mã hoá toàn thiết bị của hệ điều hành (FBE/FDE Android)	Bảo vệ dữ liệu khi thiết bị ở trạng thái tắt hoặc chưa mở khoá lần đầu	Khi máy đã mở khoá, mọi ứng dụng và người cầm máy đều thấy dữ liệu ở dạng rõ; không bảo vệ được tệp khi đưa ra khỏi thiết bị
Ứng dụng “khoá tệp”, “kết riêng tư” trên kho ứng dụng	Giao diện thuận tiện, cài đặt nhanh	Phần lớn mã nguồn đóng nên không kiểm chứng được thuật toán và cách quản lý khoá; nhiều ứng dụng yêu cầu quyền truy cập mạng hoặc đồng bộ đám mây
Trình quản lý mật khẩu (KeePassDX, Bitwarden...)	Quản lý thông tin đăng nhập rất tốt, nhiều phần mềm mã nguồn mở	Được thiết kế cho mật khẩu, không nhằm xử lý tệp, ảnh, tài liệu và các nghiệp vụ ký số, kiểm tra toàn vẹn, chia khoá phức hồi
Công cụ mật mã dòng lệnh (age, GPG, OpenSSL, VeraCrypt)	Thuật toán tin cậy, kiểm chứng được, được cộng đồng soi xét	Không có bản dùng được trên di động. Nguyên nhân kỹ thuật: hệ điều hành di động không cho ứng dụng sinh tiến trình con để chạy tệp nhị phân (xem mục 3.2.2)
Ứng dụng nhắn tin mã hoá đầu-cuối	Bảo vệ rất tốt dữ liệu trên đường truyền	Không bảo vệ dữ liệu ở trạng thái lưu trữ trên máy; dữ liệu vẫn đi qua hạ tầng của nhà cung cấp dịch vụ
Giải pháp quản lý thiết bị/chống thất thoát dữ liệu (MDM/DLP)	Quản lý tập trung, phù hợp quy mô lớn	Cần hạ tầng máy chủ, chi phí bản quyền và phụ thuộc nhà cung cấp; khó triển khai cho nhu cầu cá nhân và nhóm nhỏ

Để so sánh khách quan hơn, Bảng 3 đối chiếu theo từng tiêu chí có thể kiểm tra được, thay vì nhận định định tính.

Bảng 3. Ma trận đối chiếu theo tiêu chí kiểm tra được

Tiêu chí	Mã hoá toàn thiết bị	Ứng dụng kết thương mại	Công cụ đồng lệnh	SecureVault Mobile
Chạy được trên Android	Có	Có	Không	Có
Không yêu cầu quyền mạng	Có	Thường không	Có	Có
Mã nguồn kiểm tra được	Một phần	Thường không	Có	Có
Có bộ kiểm thử công khai	Không rõ	Không	Có	Có
Bảo vệ tệp sau khi rời thiết bị	Không	Một phần	Có	Có
Ký số và kiểm tra nguồn gốc	Không	Hiếm	Có	Có
Chia khoá phục hồi k trong n	Không	Hiếm	Một phần	Có
Định dạng tệp theo chuẩn mở	Không áp dụng	Thường không	Có	Có
Dùng được làm học cụ giảng dạy	Hạn chế	Hạn chế	Có	Có

Đánh giá dựa trên đặc điểm chung của từng nhóm giải pháp; “Hiếm” nghĩa là có sản phẩm đáp ứng nhưng không phổ biến. Cột SecureVault Mobile đối chiếu với chức năng đã hiện thực và kiểm chứng, không phải chức năng dự kiến.

1.3. Khoảng trống mà sáng kiến hướng tới

Từ phân tích trên, khoảng trống được xác định là: chưa có công cụ đồng thời đáp ứng cả năm yêu cầu sau đây trên nền tảng Android.

- **Yêu cầu 1.** Hoạt động hoàn toàn trên thiết bị, không yêu cầu quyền truy cập mạng, không tài khoản, không đồng bộ đám mây.
- **Yêu cầu 2.** Mã nguồn kiểm soát được, thuật toán công khai, có bộ kiểm thử tự động để bên thứ ba có thể kiểm chứng lại.
- **Yêu cầu 3.** Gộp nhiều nghiệp vụ bảo vệ dữ liệu trong một ứng dụng thống nhất, thay vì phải dùng nhiều công cụ rời rạc.

- **Yêu cầu 4.** Tệp tạo ra tương thích với chuẩn mở, không khoá người dùng vào một sản phẩm duy nhất.
- **Yêu cầu 5.** Đồng thời sử dụng được làm học cụ trực quan cho giảng dạy an toàn thông tin.

Định hướng của sáng kiến

SecureVault Mobile được xây dựng để đáp ứng đồng thời cả năm yêu cầu trên, với ưu tiên cao nhất là mọi tuyên bố kỹ thuật đều phải kèm bằng chứng kiểm chứng được.

2. Mục đích của giải pháp

Sáng kiến nhằm xây dựng một ứng dụng Android giúp người dùng tự bảo vệ dữ liệu nhạy cảm ngay trên thiết bị của mình, đồng thời trở thành học cụ phục vụ giảng dạy và huấn luyện an toàn thông tin. Các mục tiêu cụ thể như sau.

- **Mục tiêu 1 – Bảo vệ dữ liệu tại chỗ:** Cung cấp cơ chế mã hoá, ký số, kiểm tra toàn vẹn và chia khoá phục hồi hoạt động hoàn toàn trên thiết bị, không phụ thuộc kết nối mạng hay dịch vụ bên ngoài.
- **Mục tiêu 2 – Bảo đảm chủ quyền dữ liệu:** Khoá và dữ liệu do người dùng nắm giữ hoàn toàn; ứng dụng không khai báo quyền truy cập mạng nên về mặt kỹ thuật không thể gửi dữ liệu ra ngoài.
- **Mục tiêu 3 – Kiểm chứng được:** Toàn bộ mã nguồn mở kèm 267 hàm kiểm thử tự động, cho phép kiểm tra lại các tuyên bố kỹ thuật thay vì phải tin vào lời khẳng định.
- **Mục tiêu 4 – Phục vụ đào tạo:** Mỗi chức năng tương ứng với một nguyên lý an toàn thông tin cụ thể, cho phép giảng viên minh hoạ trực quan và xây dựng bài thực hành.
- **Mục tiêu 5 – Sử dụng được ngay:** Giao diện tiếng Việt, thao tác theo từng bước, thuật ngữ kỹ thuật được đặt trong mục mở rộng để không gây quá tải cho người mới.

3. Mô tả giải pháp

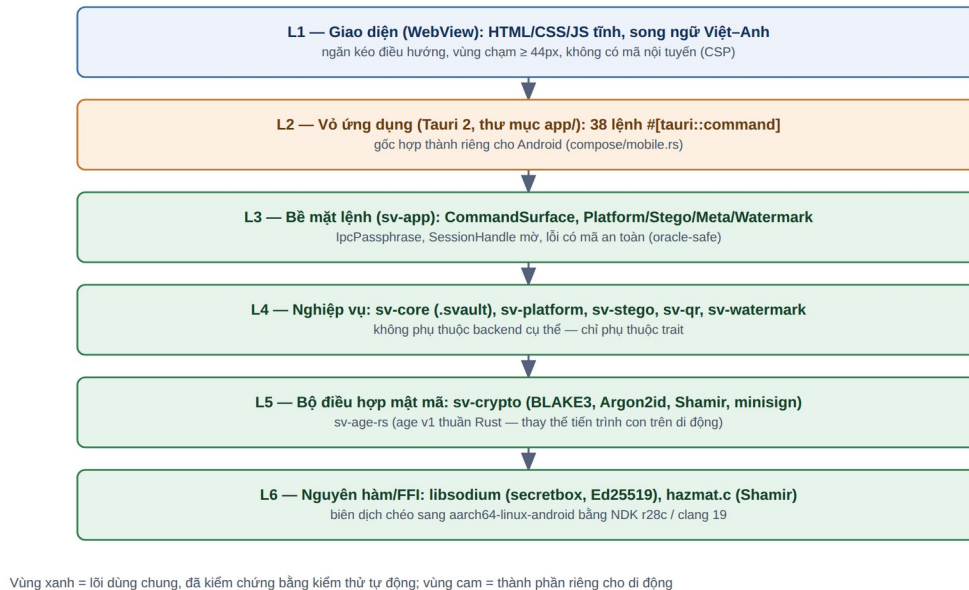
3.1. Nguyên lý của giải pháp

Giải pháp được xây dựng trên sáu nguyên lý nhất quán, chi phối toàn bộ thiết kế và được thể hiện trực tiếp trong mã nguồn.

- **Nguyên lý 1 – Ngoại tuyến tuyệt đối:** Ứng dụng không khai báo quyền truy cập mạng. Đây không phải là lựa chọn cấu hình mà là ràng buộc ở mức hệ điều hành: không có quyền thì tiến trình không thể mở kết nối.
- **Nguyên lý 2 – Một lõi bảo mật dùng chung:** Toàn bộ nghiệp vụ mật mã nằm trong 14 thành phần Rust độc lập với giao diện. Nhờ vậy phần dễ thay đổi (giao diện) không thể vô tình làm sai lệch phần cần ổn định (mật mã).
- **Nguyên lý 3 – Phụ thuộc một chiều theo lớp:** Lớp trên gọi lớp dưới, không có chiều ngược lại. Lõi mật mã không biết gì về giao diện hay nền tảng, nên có thể kiểm thử độc lập và tái sử dụng.
- **Nguyên lý 4 – Suy giảm chức năng an toàn (fail-closed):** Khi một thành phần không sẵn sàng, chức năng liên quan bị vô hiệu hoá và báo rõ cho người dùng, thay vì chạy tiếp trong trạng thái không bảo đảm.
- **Nguyên lý 5 – Thông báo lỗi không tạo kênh phân biệt:** Các tình huống thất bại được quy về tập mã lỗi thống nhất, tránh để kẻ tấn công dựa vào sự khác biệt của thông báo mà suy đoán bí mật.
- **Nguyên lý 6 – Không lưu bí mật:** Mật khẩu chỉ tồn tại trong bộ nhớ trong thời gian xử lý và được xoá ngay sau đó; khoá chính không bao giờ được ghi xuống bộ nhớ lưu trữ.

Hình 2. Kiến trúc phân lớp của SecureVault Mobile (Android)

Sáu lớp, phụ thuộc một chiều từ trên xuống; lỗi mật mã không phụ thuộc giao diện



Hình 2. Kiến trúc phân lớp của SecureVault Mobile

3.2. Các nội dung chủ yếu

3.2.1. Kiến trúc tổng thể

Ứng dụng gồm sáu lớp (Hình 2). Lớp giao diện chạy trong WebView, giao tiếp với phần lõi qua đúng 38 lệnh có kiểm soát. Lớp bề mặt lệnh đóng vai trò cổng vào duy nhất của lõi: mọi mật khẩu đi qua đây đều được bọc trong kiểu dữ liệu tự xoá, và phiên làm việc chỉ được tham chiếu bằng một mã định danh mờ, không mang thông tin bí mật.

3.2.2. Rào cản kỹ thuật của nền tảng di động và cách vượt qua

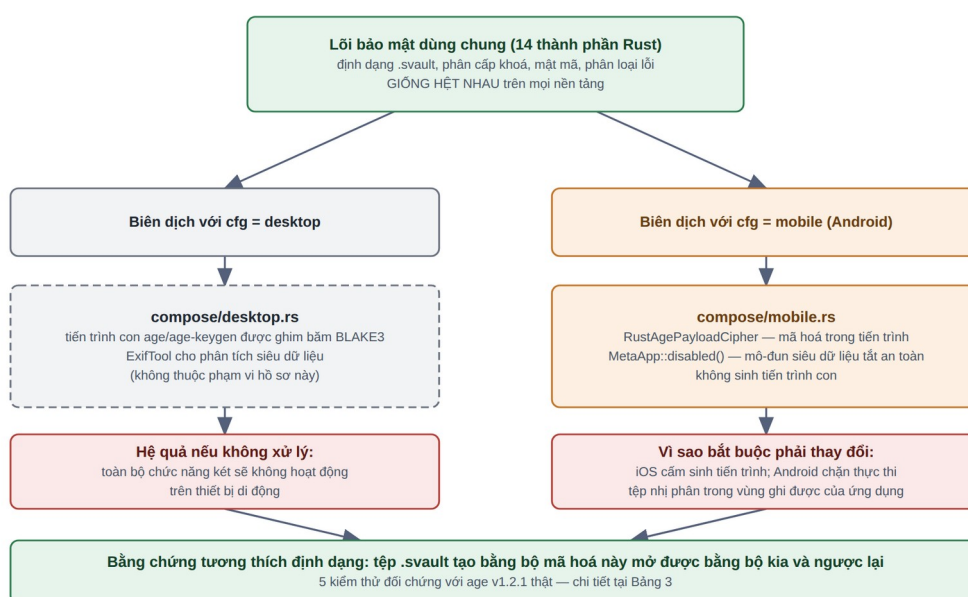
Đây là nội dung mang hàm lượng kỹ thuật cao nhất của sáng kiến và cũng là lý do các công cụ mật mã dòng lệnh mạnh hiện nay không có bản dùng được trên điện thoại.

Vấn đề. Các công cụ mật mã tin cậy như `age` hay `ExifTool` được phân phối dưới dạng tệp nhị phân chạy độc lập. Trên máy tính để bàn, ứng dụng có thể gọi chúng như một tiến trình con. Trên thiết bị di động thì không: iOS cấm hoàn toàn việc sinh tiến trình, còn Android chặn thực thi tệp nhị phân nằm trong vùng lưu trữ mà ứng dụng ghi được. Hệ quả là toàn bộ chức năng phụ thuộc tiến trình con sẽ không hoạt động, kể cả khi mã nguồn biên dịch thành công.

Cách giải quyết. Thay vì viết lại ứng dụng cho di động, sáng kiến đặt một **điểm nối trừu tượng** tại đúng vị trí bộ mã hoá nội dung kết. Nhờ điểm nối này, có thể thay bộ mã hoá dạng tiến trình con bằng một bộ mã hoá chạy ngay trong tiến trình ứng dụng, **mà không thay đổi định dạng tệp**. Việc lựa chọn bộ mã hoá nào diễn ra tự động tại thời điểm biên dịch theo nền tảng (Hình 3).

Hình 3. Một lỗi bảo mật, hai gốc hợp thành theo nền tảng

Rào cản kỹ thuật và cách giải quyết đã được kiểm chứng bằng thực nghiệm



Hình 3. Một lỗi bảo mật, hai gốc hợp thành theo nền tảng

Vì sao đây là điểm mấu chốt. Một giải pháp thay bộ mã hoá mà làm đổi định dạng tệp sẽ khiến dữ liệu cũ không mở được và người dùng bị khoá vào một phiên bản. Do đó tính tương thích định dạng không phải là chi tiết kỹ thuật phụ mà là điều

kiện bắt buộc, và đã được kiểm chứng bằng thực nghiệm đối chứng chứ không phải bằng suy luận (Bảng 4).

Bảng 4. Kiểm chứng tương thích định dạng giữa hai bộ mã hoá

Phép kiểm chứng	Nội dung	Kết quả
Đối chứng mức tệp mã hoá (chiều 1)	Dữ liệu do bộ mã hoá trong tiến trình tạo ra, giải mã bằng công cụ age v1.2.1 chính thức	Đạt
Đối chứng mức tệp mã hoá (chiều 2)	Dữ liệu do công cụ age v1.2.1 chính thức tạo ra, giải mã bằng bộ mã hoá trong tiến trình	Đạt
Mở chéo kết (chiều 1)	Kết tạo bằng bộ mã hoá tiến trình con, mở bằng bộ mã hoá trong tiến trình	Đạt
Mở chéo kết (chiều 2)	Kết tạo bằng bộ mã hoá trong tiến trình, mở bằng bộ mã hoá tiến trình con	Đạt
Giữ nguyên hàng rào xác thực	Sau khi thay bộ mã hoá, mật khẩu sai vẫn bị từ chối đúng cách	Đạt

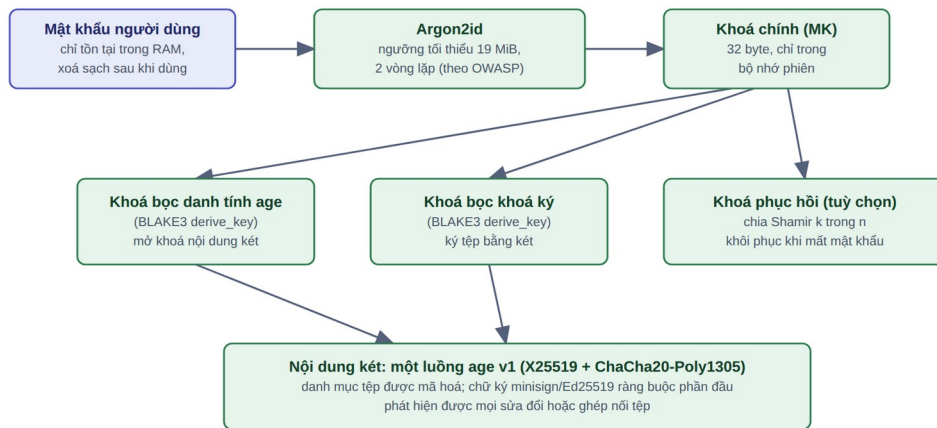
Nguồn: crates/sv-age-rs/tests/interop.rs và src-tauri/tests/vault_interop.rs. Các phép kiểm chứng này chạy đối chứng với công cụ age v1.2.1 tải từ nguồn chính thức, có lưu lại giá trị băm SHA-256 của tệp tải về để truy vết.

3.2.3. Phân cấp khoá và bảo vệ mật khẩu

Mật khẩu người dùng không được lưu ở bất kỳ đâu. Từ mật khẩu, ứng dụng dẫn xuất khoá chính bằng thuật toán Argon2id với tham số tối thiểu 19 MiB bộ nhớ và 2 vòng lặp — đạt ngưỡng khuyến nghị của OWASP nhằm làm chậm đáng kể tấn công dò mật khẩu bằng phần cứng chuyên dụng. Khoá chính chỉ tồn tại trong bộ nhớ phiên làm việc và sinh ra các khoá con theo từng mục đích riêng biệt (Hình 4).

Hình 4. Phân cấp khoá và luồng mở kết an toàn

Mật khẩu không bao giờ được lưu; khoá chính chỉ tồn tại trong bộ nhớ phiên



Sai mật khẩu và tệp hỏng trả về hai mã lỗi khác nhau nhưng không tiết lộ thông tin phân biệt được (oracle-safe)

Hình 4. Phân cấp khoá và luồng mở kết an toàn

Bảng 5. Các thuật toán mật mã được sử dụng

Chức năng	Thuật toán	Vai trò trong hệ thống
Dẫn xuất khoá từ mật khẩu	Argon2id	Chống dò mật khẩu; tham số tối thiểu 19 MiB / 2 vòng
Băm và dẫn xuất khoá con	BLAKE3	Kiểm tra toàn vẹn; tách khoá theo mục đích
Mã hoá nội dung kết	age v1 (X25519 + ChaCha20-Poly1305)	Bảo mật và toàn vẹn nội dung kết
Bọc trường dữ liệu	XSalsa20-Poly1305 (libsodium secretbox)	Bảo vệ các trường khoá trong phần đầu tệp
Chữ ký số	Ed25519 (định dạng minisign)	Chứng minh nguồn gốc và phát hiện sửa đổi
Chia sẻ bí mật	Shamir k-trong-n (sss hazmat.c)	Khôi phục khi mất mật khẩu, không cần bên thứ ba

Nguồn: [crates/sv-crypto-traits/src/lib.rs](#) và [crates/sv-crypto/src/policy.rs](#).

3.2.4. Nhóm chức năng

Ứng dụng cung cấp 38 lệnh nghiệp vụ, được nhóm thành sáu nhóm theo mục đích sử dụng thay vì theo thuật toán, giúp người dùng chọn công cụ theo việc cần làm.

Bảng 6. Nhóm chức năng của SecureVault Mobile

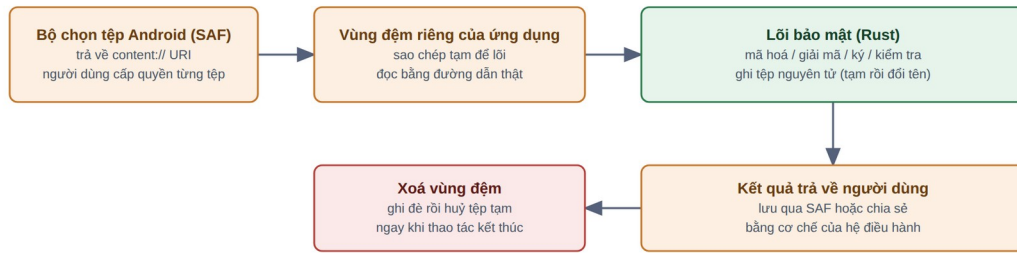
Nhóm	Chức năng chính	Nguyên lý ATTT minh hoạ
Kết an toàn	Tạo/mở kết, thêm và trích xuất tệp, đổi mật khẩu, ký tệp bằng kết	Mã hoá có xác thực; phân cấp khoá; quản lý phiên
Bảo vệ tệp đơn lẻ	Khoá và mở khoá một tệp bằng mật khẩu	Mã hoá đối xứng; dẫn xuất khoá từ mật khẩu
Chứng minh tính xác thực	Ký tệp, kiểm tra chữ ký, lấy và đối chiếu vân tay tệp	Chữ ký số; hàm băm mật mã; kiểm tra toàn vẹn
Sao lưu và khôi phục	Chia bí mật/tệp thành k trong n mảnh, khôi phục, chuyển qua mã QR	Chia sẻ bí mật ngưỡng; tách quyền kiểm soát
Che giấu dữ liệu	Giấu dữ liệu trong ảnh, trích xuất, phát hiện dấu hiệu ẩn	Giấu tin; phân tích giấu tin
Chống giả mạo	Nhúng và kiểm tra thuỷ vân để vỡ trên ảnh	Thuỷ vân số; phát hiện sửa đổi cục bộ

3.2.5. Luồng xử lý tệp trên Android

Android không cho ứng dụng truy cập tự do vào bộ nhớ thiết bị. Người dùng chọn tệp qua bộ chọn của hệ điều hành và cấp quyền cho từng tệp. Ứng dụng đưa dữ liệu vào vùng lưu trữ riêng, xử lý, trả kết quả rồi xoá vùng đệm (Hình 5).

Hình 5. Luồng xử lý tệp trên Android và ranh giới tin cậy

Mọi xử lý diễn ra trên thiết bị; không có kết nối mạng trong toàn bộ luồng



Ranh giới tin cậy: toàn bộ khối trên nằm trong vùng lưu trữ riêng của ứng dụng, được hệ điều hành cách ly và mã hoá ở mức tệp (File-Based Encryption).

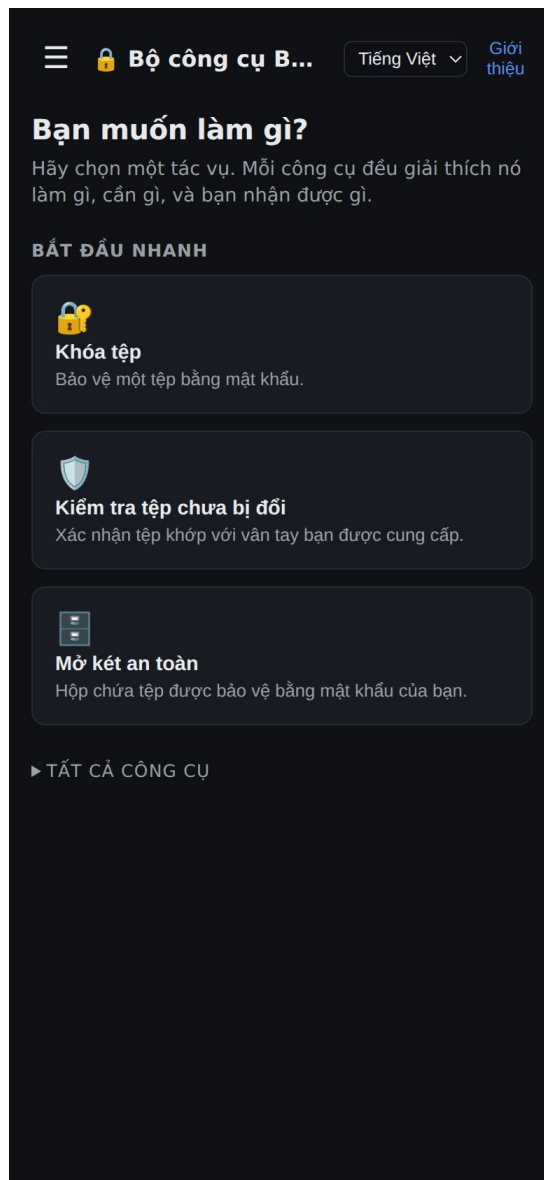
Ứng dụng KHÔNG khai báo quyền truy cập mạng (INTERNET).

Điểm cần ghi nhận trung thực: bản sao tạm ở dạng rõ tồn tại trong vùng đệm trong thời gian thao tác — đã được ghi nhận trong mô hình mối đe dọa.

Hình 5. Luồng xử lý tệp trên Android và ranh giới tin cậy

3.2.6. Giao diện người dùng

Giao diện được thiết kế theo hướng giảm tải nhận thức: mỗi màn hình chỉ hiển thị các bước cần thiết để hoàn thành công việc, phần giải thích kỹ thuật đặt trong mục “Thông tin thêm” có thể mở rộng. Cảnh báo có nguy cơ gây mất dữ liệu vĩnh viễn được giữ hiển thị thường trực. Toàn bộ giao diện có tiếng Việt và tiếng Anh.



Hình 6. Màn hình chính (kết xuất giao diện ở kích thước điện thoại)

Bộ công cụ B...

Tiếng Việt

Gới thiệu

Khóa tệp bằng mật khẩu

Biến bất kỳ tệp nào thành tệp đã khóa mà chỉ mật khẩu của bạn mới mở được.

[Thông tin thêm](#)

1 Chọn tệp cần khóa

Kéo thả tệp vào đây, hoặc bấm Duyệt...

Duyệt...

2 Đặt mật khẩu

mật khẩu

Xác nhận mật khẩu

nhập lại mật khẩu

Gõ sai ở đây là không thể khôi phục — tệp sẽ không bao giờ mở được.

3 Nơi lưu tệp đã khóa

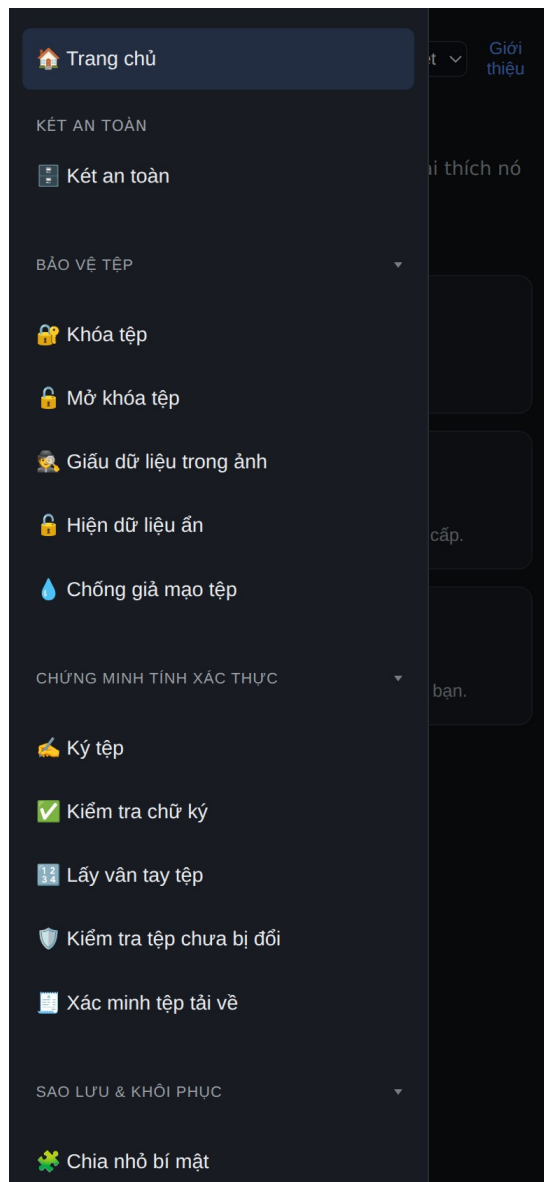
/đường-dẫn/tôi/tệp.svenc

Lưu thành...

Khóa tệp

Hình 7. Màn hình khoá tệp — thao tác theo ba bước (kết xuất giao diện)

18



Hình 8. Ngăn kéo điều hướng nhóm công cụ theo mục đích sử dụng



Hình 9. Màn hình chia bí mật theo ngưỡng k trong n

Ghi chú về ảnh chụp giao diện: các hình trên được kết xuất từ chính mã giao diện của sản phẩm ở kích thước màn hình điện thoại, với cầu nối tới lõi được mô phỏng trả về đúng giá trị mà gốc hợp thành Android tạo ra. Nhờ vậy logic giao diện thật được thực thi. Ảnh chụp trên thiết bị Android thật sẽ được bổ sung theo Phụ lục B.

3.3. Kết quả của giải pháp

3.3.1. Sản phẩm đã tạo ra

- Ứng dụng Android đóng gói dạng APK (47.4 MB), chứa lõi bảo mật biên dịch cho kiến trúc ARM64; đã kiểm tra tĩnh nội dung gói.
- Mã nguồn đầy đủ gồm 14 thành phần Rust và giao diện web tĩnh, kèm 267 hàm kiểm thử tự động.
- Bộ tài liệu kiến trúc, mô hình mối đe dọa và hướng dẫn triển khai.
- Quy trình kiểm thử tự động chạy trên máy chủ tích hợp liên tục.

3.3.2. Mức độ kiểm chứng

Tác giả xác định rõ ranh giới giữa điều đã chứng minh được bằng máy và điều còn phải kiểm tra trên thiết bị thật. Đây là nguyên tắc xuyên suốt hồ sơ: không mô tả phần chưa kiểm chứng như đã hoàn thành.

Hình 6. Các mức kiểm chứng đã đạt được và phần còn lại

Phân biệt rõ điều đã chứng minh bằng máy và điều còn phải kiểm tra trên thiết bị thật



Nguyên tắc của hồ sơ: mỗi tuyên bố kỹ thuật đều gắn với một mức kiểm chứng cụ thể ở trên.

Hình 10. Các mức kiểm chứng đã đạt được và phần còn lại

Về mức 4, việc thực thi trên ARM64 được tiến hành bằng trình giả lập kiến trúc trên bộ ba đích aarch64-unknown-linux-gnu, chạy 10 bộ kiểm thử của các thành phần mật mã và FFI với kết quả 146 đạt, 0 lỗi. Cần nói rõ: đây là kiểm chứng mã máy ARM64 của lõi, không phải chạy tệp nhị phân Android — vì tệp nhị phân Android liên kết với thư viện chuẩn riêng của nền tảng mà trình giả lập không phân giải được

nếu thiếu bộ thư viện hệ thống Android. Phần kiểm chứng trên môi trường Android thật thuộc mức 6 và chưa thực hiện.

3.3.3. Kiểm chứng gói cài đặt Android

Ba tuyên bố quan trọng của hồ sơ được kiểm chứng trực tiếp từ chính tệp cài đặt, không dựa vào khẳng định của tác giả. Bất kỳ ai có tệp APK đều có thể lặp lại các phép kiểm tra này bằng công cụ tiêu chuẩn.

Bảng 7. Kiểm chứng gói cài đặt Android

Nội dung kiểm chứng	Kết quả	Cách kiểm chứng
Thư viện lõi bảo mật đúng kiến trúc	64-bit ARM aarch64	Đọc phần đầu ELF của tệp .so trong gói
Danh sách quyền ứng dụng yêu cầu	Rỗng — không khai báo quyền nào	Đọc tệp kê khai của gói
Giao diện nhúng sẵn trong ứng dụng	Có	Bảng tài nguyên bên trong thư viện native
Kích thước gói cài đặt	47.4 MB	Thuộc tính tệp
Giá trị băm SHA-256	1eb5ebad01eb3a9f74b4d33a3f4c8f3c...	Tính trực tiếp trên tệp APK

Nguồn: [hoso-sang-kien/kiem-tra-apk.py](https://github.com/hoso-sang-kien/kiem-tra-apk.py), kết quả lưu tại [hoso-sang-kien/bang-chung/kiem-tra-apk.json](https://github.com/hoso-sang-kien/bang-chung/kiem-tra-apk.json). Việc ứng dụng không khai báo quyền truy cập mạng là bằng chứng kỹ thuật cho tính ngoại tuyến: tiến trình không có quyền thì không thể mở kết nối.

4. Tự đánh giá giải pháp

4.1. Tính mới và tính sáng tạo

Tác giả xác định tính mới của sáng kiến không nằm ở việc “có thêm một ứng dụng mã hoá”, mà nằm ở cách giải quyết những vấn đề kỹ thuật cụ thể mà các giải pháp hiện có chưa xử lý được trên nền tảng di động. Dưới đây là năm điểm mới, mỗi điểm kèm bằng chứng có thể kiểm tra lại trong mã nguồn.

4.1.1. Phân định rõ phần kế thừa và phần do tác giả xây dựng

Trong lĩnh vực mật mã, việc tự thiết kế thuật toán mới là điều phải tránh: nguyên tắc nghề nghiệp là sử dụng các thuật toán đã được cộng đồng khoa học kiểm chứng lâu dài. Do đó tác giả sử dụng các thuật toán chuẩn và không coi đó là đóng góp của mình. Đóng góp của tác giả nằm ở kiến trúc, ở cách giải quyết rào cản nền tảng, ở phương pháp kiểm chứng và ở việc tích hợp thành một sản phẩm dùng được. Bảng 8 phân định rõ hai phần này.

Bảng 8. Phân định phần kế thừa và phần do tác giả xây dựng

Thành phần	Nguồn gốc	Ghi chú
Thuật toán Argon2id, BLAKE3, ChaCha20-Poly1305, Ed25519, Shamir	Kế thừa — tiêu chuẩn công khai	Sử dụng thư viện đã được kiểm chứng; không tự thiết kế thuật toán
Định dạng tệp mã hoá age v1	Kế thừa — đặc tả mở	Giữ nguyên để bảo đảm tương thích, không tạo định dạng riêng
Kiến trúc phân lớp và ranh giới phụ thuộc một chiều	Tác giả xây dựng	Quyết định lỗi mật mã không phụ thuộc giao diện và nền tảng
Định dạng vùng chứa .svault và phân cấp khoá	Tác giả xây dựng	Phần đầu tệp, danh mục tệp được mã hoá, chữ ký ràng buộc chống ghép nối
Điểm nối trừu tượng cho bộ mã hoá nội dung	Tác giả xây dựng	Chính là cơ chế cho phép vượt rào cản cấm sinh tiến trình trên di động
Bộ điều hợp mã hoá trong tiến trình cho di động	Tác giả xây dựng	Viết mới, dùng thư viện mật mã chuẩn, giữ nguyên định dạng tệp
Phân loại lỗi an toàn trước tấn công oracle	Tác giả xây dựng	Quy tắc quy lỗi thống nhất giữa các nền tảng, có kiểm thử riêng
Cơ chế suy giảm chức năng an toàn	Tác giả xây dựng	Phát hiện thành phần không sẵn sàng ngay khi khởi động

		và vô hiệu hoá đúng cách
Gốc hợp thành riêng theo nền tảng	Tác giả xây dựng	Cho phép một lõi phục vụ nhiều nền tảng mà không tách nhánh mã nguồn
Giao diện, nội dung tiếng Việt, luồng thao tác	Tác giả xây dựng	Thiết kế theo hướng giảm tải nhận thức cho người dùng không chuyên
Bộ kiểm thử tự động và phương pháp kiểm chứng	Tác giả xây dựng	267 hàm kiểm thử, gồm kiểm chứng đối chứng với công cụ chuẩn

Việc phân định này nhằm bảo đảm hồ sơ không nhận công cho phần kế thừa, đồng thời làm rõ hàm lượng kỹ thuật thực sự do tác giả tạo ra.

4.1.2. Năm điểm mới của giải pháp

Điểm mới 1. Vượt rào cản cấm sinh tiến trình mà không phá vỡ định dạng dữ liệu

Các công cụ mật mã tin cậy hiện nay phần lớn ở dạng tệp nhị phân chạy độc lập, nên không chuyển thẳng sang di động được. Sáng kiến đặt điểm nổi trù tượng tại vị trí bộ mã hoá nội dung, cho phép thay thế bằng bộ mã hoá chạy trong tiến trình mà tệp tạo ra vẫn đọc được bằng công cụ chuẩn. Cách làm này giữ được tính tương thích với hệ sinh thái mở, tránh khoá người dùng vào một sản phẩm.

Bảng chứng: Năm phép kiểm chứng đối chứng hai chiều với công cụ age v1.2.1 chính thức (Bảng 4).

Điểm mới 2. Một lõi bảo mật dùng chung, tự chọn cấu hình theo nền tảng khi biên dịch

Thay vì viết hai ứng dụng song song rồi phải đồng bộ thủ công, toàn bộ nghiệp vụ mật mã nằm trong một lõi duy nhất; phần khác biệt giữa các nền tảng được cô lập trong một tệp cấu hình hợp thành và được trình biên dịch tự động lựa chọn. Nhờ vậy không tồn tại nguy cơ hai nền tảng dùng hai phiên bản thuật toán khác nhau.

Bảng chứng: Kiểm tra trực tiếp kết quả biên dịch cho thấy hai nền tảng chọn đúng hai gốc hợp thành khác nhau từ cùng một mã nguồn.

Điểm mới 3. Suy giảm chức năng an toàn được thiết kế sẵn, không phải xử lý lỗi bổ sung

Mô-đun phân tích siêu dữ liệu không thể chạy trên di động vì phụ thuộc tiến trình con. Thay vì báo lỗi khó hiểu khi người dùng bấm nút, ứng dụng phát hiện tình trạng

này ngay khi khởi động, vô hiệu hoá các nút liên quan và giải thích lý do bằng tiếng Việt.

Bằng chứng: Trạng thái này dùng lại đúng cơ chế đã có sẵn trong thiết kế, không phải mã xử lý riêng cho di động; minh hoạ tại Hình 9.

Điểm mới 4. Thông báo lỗi không tạo kênh phân biệt cho kẻ tấn công

Hệ thống phân biệt rõ ở tầng mã giữa “sai mật khẩu” và “tệp bị hỏng hoặc bị sửa”, nhưng không để sự khác biệt đó trở thành công cụ dò tìm. Cụ thể, thất bại khi giải mã nội dung được quy về lỗi “tệp hỏng” chứ không phải “sai xác thực”, vì tại thời điểm đó chữ ký ràng buộc và khoá đã được xác thực xong.

Bằng chứng: Có kiểm thử riêng khẳng định cả hai bộ mã hoá dùng chung một cách quy lỗi, để hai nền tảng không thể lệch nhau về hành vi này.

Điểm mới 5. Ngoại tuyến bằng ràng buộc kỹ thuật thay vì bằng cam kết

Ứng dụng không khai báo quyền truy cập mạng trong tệp kê khai. Người dùng không phải tin vào lời hứa “chúng tôi không gửi dữ liệu đi”, mà có thể tự kiểm tra bằng công cụ phân tích gói cài đặt tiêu chuẩn.

Bằng chứng: Kiểm tra tệp kê khai của gói APK đã đóng gói (mục 3.3.2).



Hình 11. Cơ chế suy giảm an toàn: chức năng không khả dụng được vô hiệu hoá và giải thích rõ, thay vì báo lỗi khi người dùng thao tác

Giá trị kép của sáng kiến

Cùng một sản phẩm phục vụ đồng thời hai mục đích: là công cụ bảo vệ dữ liệu dùng được trong công tác, và là học cụ trực quan cho giảng dạy an toàn thông tin. Mã nguồn mở kèm bộ kiểm thử cho phép học viên đọc, chạy lại và sửa đổi để hiểu nguyên lý — điều mà phần mềm thương mại mã nguồn đóng không đáp ứng được.

4.2. Khả năng áp dụng

Sáng kiến có khả năng áp dụng ngay với điều kiện triển khai tối thiểu: chỉ cần một điện thoại Android, không cần máy chủ, không cần kết nối mạng, không phát sinh chi phí bản quyền. Ba nhóm đối tượng áp dụng được xác định như sau.

Bảng 9. Đối tượng và phạm vi áp dụng

Đối tượng	Cách sử dụng	Điều kiện cần
Giảng viên an toàn thông tin	Bảo vệ giáo án, đề bài và đáp án thực hành, kết quả nghiên cứu chưa công bố; dùng làm học cụ minh họa trên lớp	Điện thoại Android; không cần hạ tầng bổ sung
Học viên	Thực hành các bài về mã hoá, chữ ký số, chia sẻ bí mật ngưỡng, kiểm tra toàn vẹn, giấu tin và phát hiện giấu tin	Điện thoại Android hoặc máy tính có trình giả lập
Cán bộ, nhân viên trong đơn vị	Bảo vệ tài liệu nghiệp vụ nội bộ khi mang theo trên thiết bị di động; kiểm tra tính toàn vẹn của tệp nhận được	Điện thoại Android; hướng dẫn sử dụng ngắn

4.2.1. Giá trị cụ thể đối với công tác giảng dạy an toàn thông tin

Điểm mạnh của sản phẩm trong đào tạo là mỗi chức năng đều tương ứng với một nguyên lý trong chương trình an toàn thông tin, và học viên có thể quan sát trực tiếp hệ quả của nguyên lý đó trên thiết bị của mình thay vì chỉ nghe giảng lý thuyết.

Bảng 10. Ánh xạ chức năng của sản phẩm với nội dung giảng dạy

Chức năng	Nội dung giảng dạy minh họa	Gợi ý bài thực hành
Tạo và mở kết an toàn	Dẫn xuất khoá từ mật khẩu; vì sao mật khẩu yếu vẫn nguy hiểm dù thuật toán mạnh	So sánh thời gian mở kết khi thay đổi tham số dẫn xuất khoá
Khoá / mở khoá tệp	Mã hoá có xác thực; phân biệt bảo mật và toàn vẹn	Sửa một byte của tệp đã mã hoá rồi quan sát ứng dụng từ chối giải mã
Ký tệp và kiểm tra chữ ký	Mật mã khoá công khai; chứng minh nguồn gốc	Ký tệp, đổi một ký tự trong tệp, kiểm tra lại chữ ký
Vân tay tệp và kiểm tra toàn vẹn	Hàm băm mật mã; ứng dụng trong kiểm tra tệp tải về	Đối chiếu vân tay của cùng một tệp trên hai thiết bị

Chia bí mật k trong n	Chia sẻ bí mật ngưỡng; nguyên tắc tách quyền kiểm soát	Chia khoá cho ba học viên, chứng minh hai người mới khôi phục được
Giấu tin và phát hiện giấu tin	Giấu tin trong ảnh; giới hạn của việc che giấu so với mã hoá	Giấu tệp vào ảnh rồi dùng chính công cụ phát hiện để tìm dấu hiệu
Thuỷ vân dễ vỡ	Phát hiện sửa đổi cục bộ trên ảnh	Chỉnh sửa một vùng ảnh đã đóng dấu và xác định vùng bị sửa
Cơ chế suy giảm an toàn	Nguyên tắc fail-closed trong thiết kế hệ thống an toàn	Phân tích vì sao tắt chức năng an toàn hơn chạy tiếp trong trạng thái không bảo đảm

Ngoài giá trị minh hoạ, mã nguồn mở còn cho phép tổ chức các bài học ở mức cao hơn: đọc và phân tích cách hiện thực một nguyên lý, nhận xét về mô hình mối đe dọa, hoặc rà soát mã nguồn để tìm điểm cần cải thiện. Đây là hình thức huấn luyện sát thực tế mà tài liệu lý thuyết đơn thuần khó thay thế.

4.2.2. Ý nghĩa đối với công tác bảo đảm an toàn thông tin của đơn vị

- Giảm phụ thuộc vào dịch vụ và hạ tầng bên ngoài: toàn bộ quá trình xử lý dữ liệu diễn ra trên thiết bị, khoá do người dùng nắm giữ, không có thành phần máy chủ.
- Kiểm soát được thành phần phần mềm: mã nguồn mở, danh mục thư viện phụ thuộc được rà soát tự động về giấy phép và lỗ hổng đã công bố.
- Hạn chế thói quen chuyển tài liệu nội bộ qua các ứng dụng nhắn tin hoặc lưu trữ đám mây không kiểm soát, bằng cách cung cấp một phương án thay thế thuận tiện ngay trên máy.
- Nâng cao nhận thức: người dùng trực tiếp thao tác với mã hoá, chữ ký số và kiểm tra toàn vẹn nên hiểu rõ hơn giá trị và giới hạn của từng biện pháp.

Tác giả xác định rõ phạm vi: sản phẩm là công cụ hỗ trợ kỹ thuật do tác giả tự xây dựng phục vụ công tác và huấn luyện. Việc sử dụng cho bất kỳ loại tài liệu nào phải tuân thủ quy định hiện hành của cơ quan có thẩm quyền về bảo vệ bí mật nhà nước và quy chế của đơn vị. Hồ sơ này không đưa ra bất kỳ tuyên bố nào về việc sản phẩm được phép xử lý tài liệu thuộc danh mục bí mật nhà nước ở cấp độ cụ thể.

4.3. Hiệu quả

Tác giả phân biệt rõ hai loại hiệu quả: hiệu quả đã đo được bằng số liệu khách quan tại thời điểm lập hồ sơ, và hiệu quả dự kiến khi đưa vào sử dụng thực tế — loại thứ hai chỉ có thể khẳng định sau một thời gian triển khai. Hồ sơ không đưa ra số liệu ước lượng không có căn cứ.

4.3.1. Hiệu quả kỹ thuật đã đo được

Bảng 11. Các chỉ số đã đo được tại thời điểm lập hồ sơ

Chỉ số	Giá trị	Nguồn số liệu
Số lệnh nghiệp vụ cung cấp	38 lệnh	Đếm trực tiếp từ mã nguồn
Số hàm kiểm thử tự động	267 hàm	Đếm trực tiếp từ mã nguồn
Kiểm thử trên máy chủ	258 đạt / 0 lỗi	Nhật ký chạy cargo test
Kiểm thử lỗi mật mã trên ARM64 (giả lập QEMU), 10 bộ kiểm thử	146 đạt / 0 lỗi	Nhật ký chạy dưới QEMU
Kiểm chứng tương thích định dạng	3 đạt / 0 lỗi	Đối chứng với age v1.2.1 chính thức
Yêu cầu quyền truy cập mạng	Không khai báo	Kiểm tra tệp kê khai của gói APK
Chi phí bản quyền phần mềm	Không	Toàn bộ thành phần dùng giấy phép mở
Yêu cầu hạ tầng máy chủ	Không	Thiết kế không có thành phần máy chủ

Các số liệu trên được sinh tự động từ mã nguồn và nhật ký kiểm thử, không nhập tay, nhằm bảo đảm tính chính xác và khả năng kiểm tra lại.

4.3.2. Hiệu quả đối với công tác giảng dạy

- Rút ngắn khoảng cách giữa lý thuyết và thực hành: học viên thao tác trực tiếp trên thiết bị của mình thay vì chỉ quan sát ví dụ trên bảng.
- Tạo được các tình huống huấn luyện có kết quả quan sát được ngay, ví dụ sửa một byte trong tệp đã mã hoá và thấy hệ thống từ chối giải mã.
- Cho phép tổ chức bài học ở mức đọc và phân tích mã nguồn — hình thức huấn luyện sát thực tế mà phần mềm mã nguồn đóng không đáp ứng được.
- Giảm nhu cầu chuẩn bị phòng máy chuyên dụng cho một số bài thực hành, do công cụ chạy trên chính điện thoại của học viên.

4.3.3. Hiệu quả đối với bảo vệ dữ liệu của đơn vị

Hiệu quả trong bảo vệ dữ liệu được thể hiện qua việc thu hẹp phạm vi rủi ro chứ không phải loại bỏ hoàn toàn rủi ro. Bảng 9 trình bày rõ những mối đe dọa mà sản phẩm xử lý được và những mối đe dọa nằm ngoài khả năng của nó — việc nêu rõ giới hạn là cơ sở để sử dụng đúng và tránh chủ quan.

Bảng 12. Mô hình mối đe dọa: phạm vi bảo vệ và giới hạn

Tình huống	Sản phẩm có bảo vệ không?	Giải thích
Mất hoặc thất lạc điện thoại khi máy đang khoá	Có	Dữ liệu trong kết ở dạng mã hoá; không có mật khẩu thì không mở được
Người khác mượn máy khi máy đã mở khoá	Có, một phần	Kết vẫn cần mật khẩu riêng; nhưng nếu phiên đang mở thì nội dung có thể xem được
Sao chép tệp kết ra khỏi thiết bị	Có	Tệp kết tự bảo vệ, mở ở nơi khác vẫn cần mật khẩu
Tệp bị sửa đổi hoặc hỏng trên đường truyền	Có	Chữ ký ràng buộc phát hiện mọi thay đổi, kể cả ghép nối tệp
Lộ tệp do gửi nhầm qua ứng dụng khác	Có, một phần	Nếu gửi tệp kết thì bên nhận vẫn cần mật khẩu; nếu gửi tệp đã trích xuất thì không
Thiết bị đã bị chiếm quyền điều khiển ở mức hệ điều hành	Không	Phần mềm độc hại có quyền cao có thể đọc bộ nhớ tiến trình khi kết đang mở
Người dùng quên mật khẩu và không tạo mảnh phục hồi	Không	Không có cơ chế khôi phục dự phòng — đây là hệ quả tất yếu của việc không lưu khoá
Kẻ tấn công cưỡng ép người dùng cung cấp mật khẩu	Không	Nằm ngoài phạm vi của biện pháp kỹ thuật

Việc công bố rõ giới hạn là một phần của thiết kế: người dùng chỉ có thể sử dụng công cụ đúng cách khi biết công cụ không bảo vệ được điều gì.

4.4. Mức độ triển khai và hướng phát triển

4.4.1. Mức độ hoàn thành hiện tại

Tác giả trình bày trung thực mức độ hoàn thành theo từng hạng mục, phân biệt rõ phần đã kiểm chứng bằng máy và phần cần kiểm tra trên thiết bị thật.

Bảng 13. Mức độ hoàn thành và kiểm chứng theo hạng mục

Hạng mục	Mức độ	Cách kiểm chứng
Lỗi mật mã và nghiệp vụ	Hoàn thành	Bộ kiểm thử tự động chạy đặt trên máy chủ
Tương thích định dạng giữa hai bộ mã hoá	Hoàn thành	Đối chứng hai chiều với công cụ chuẩn
Biên dịch cho kiến trúc Android	Hoàn thành	Biên dịch thành công và kiểm tra tệp đối tượng là mã ARM64
Thực thi lỗi trên ARM64	Hoàn thành	Chạy bộ kiểm thử dưới trình giả lập kiến trúc
Giao diện cho màn hình điện thoại	Hoàn thành	Kết xuất và kiểm tra bố cục ở kích thước điện thoại
Đóng gói APK	Hoàn thành	Kiểm tra tĩnh nội dung gói cài đặt
Chạy thực tế trên điện thoại Android	Chưa kiểm chứng	Cần thiết bị thật; máy chủ xây dựng không hỗ trợ trình giả lập Android
Tích hợp kho khoá phần cứng của Android	Định hướng phát triển	Chưa hiện thực trong phiên bản này

4.4.2. Hướng phát triển

- **Hướng 1 – Hoàn tất kiểm thử trên thiết bị thật:** Cài đặt và chạy toàn bộ kịch bản nghiệp vụ trên nhiều dòng máy và nhiều phiên bản Android, ghi nhận kết quả làm cơ sở đánh giá hiệu quả thực tế.
- **Hướng 2 – Tích hợp kho khoá phần cứng và xác thực sinh trắc:** Sử dụng vùng lưu khoá được phần cứng bảo vệ của Android để lưu các thông tin không thuộc hệ thống khoá của kết, và cho phép mở khoá bằng vân tay như một tùy chọn.
- **Hướng 3 – Xây dựng bộ bài giảng và bài thực hành kèm theo:** Biên soạn tài liệu hướng dẫn giảng viên, phiếu bài thực hành và bộ dữ liệu mẫu tương ứng với Bảng 7, để có thể đưa vào chương trình huấn luyện.
- **Hướng 4 – Đánh giá độc lập:** Đề nghị đồng nghiệp và học viên rà soát mã nguồn, tổ chức đợt thử nghiệm có ghi nhận phản hồi để cải tiến.

- **Hướng 5 – Mở rộng nền tảng:** Kiến trúc lõi dùng chung đã sẵn sàng cho nền tảng khác; việc mở rộng chủ yếu là bổ sung phần vỏ ứng dụng, không phải viết lại nghiệp vụ mật mã.

Cam kết về tính trung thực của hồ sơ

Mọi số liệu trong hồ sơ được sinh tự động từ mã nguồn và nhật ký kiểm thử thật.

Những hạng mục chưa kiểm chứng được ghi rõ là “chưa kiểm chứng”, không mô tả như đã hoàn thành.

Hồ sơ không đưa ra tuyên bố về việc sản phẩm được phép xử lý tài liệu thuộc danh mục bí mật nhà nước ở bất kỳ cấp độ nào.

C. TÀI LIỆU THAM KHẢO VÀ TIÊU CHUẨN VIỆN DẪN

Các thuật toán và tham số sử dụng trong sản phẩm đều dựa trên tiêu chuẩn hoặc khuyến nghị đã công bố, không phải do tác giả tự đặt ra.

- [1] RFC 9106 — Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications (thuật toán dẫn xuất khoá từ mật khẩu).
- [2] OWASP Password Storage Cheat Sheet — khuyến nghị tham số tối thiểu cho Argon2id (19 MiB bộ nhớ, 2 vòng lặp).
- [3] RFC 8439 — ChaCha20 and Poly1305 for IETF Protocols (mã hoá có xác thực).
- [4] RFC 7748 — Elliptic Curves for Security (trao đổi khoá X25519).
- [5] RFC 8032 — Edwards-Curve Digital Signature Algorithm (chữ ký Ed25519).
- [6] A. Shamir, “How to share a secret”, Communications of the ACM, 1979 (chia sẻ bí mật ngưỡng).
- [7] BLAKE3 — đặc tả hàm băm mật mã và cơ chế dẫn xuất khoá theo ngữ cảnh.
- [8] Đặc tả định dạng age v1 — định dạng tệp mã hoá mở, dùng cho nội dung kết.
- [9] Tài liệu Android Developers — Storage Access Framework và Scoped Storage (cơ chế truy cập tệp có kiểm soát trên Android).

D. PHỤ LỤC

Phụ lục A. Quy trình kiểm thử trên thiết bị Android thật

Do máy chủ dùng để xây dựng sản phẩm không hỗ trợ ảo hoá lồng nhau nên không chạy được trình giả lập Android. Phụ lục này cung cấp quy trình để tác giả hoặc hội đồng tự kiểm chứng trên thiết bị thật. Mỗi bước có tiêu chí đạt rõ ràng để kết quả có thể ghi nhận khách quan.

Bảng 14. Quy trình kiểm thử chức năng trên thiết bị Android

TT	Nội dung kiểm thử	Thao tác	Tiêu chí đạt
1	Cài đặt	Cài tệp APK, mở ứng dụng	Ứng dụng khởi động, hiển thị màn hình chính bằng tiếng Việt
2	Không có quyền mạng	Xem mục quyền của ứng dụng trong Cài đặt hệ thống	Không có quyền truy cập mạng nào được liệt kê
3	Tạo kết	Tạo kết mới, đặt mật khẩu	Tệp kết được tạo; ứng dụng báo thành công
4	Thêm và trích xuất tệp	Thêm một tệp vào kết, khoá kết, mở lại, trích xuất	Tệp trích xuất giống hệt tệp gốc
5	Từ chối mật khẩu sai	Mở kết bằng mật khẩu sai	Ứng dụng từ chối, thông báo rõ ràng, không tiết lộ thông tin khác
6	Phát hiện sửa đổi	Dùng trình quản lý tệp sửa một byte của tệp kết rồi mở lại	Ứng dụng báo tệp bị hỏng hoặc bị sửa, không mở
7	Khoá và mở khoá tệp đơn	Khoá một ảnh, mở lại bằng đúng mật khẩu	Ảnh khôi phục nguyên vẹn
8	Ký và kiểm tra chữ ký	Tạo cặp khoá, ký một tệp, kiểm tra chữ ký	Kiểm tra đạt; sau khi sửa tệp thì kiểm tra không đạt
9	Vân tay tệp	Lấy vân tay một tệp trên hai thiết bị khác nhau	Hai giá trị vân tay trùng nhau
10	Chia và khôi phục khoá	Chia bí mật thành 3 mảnh cần 2, khôi phục bằng 2 mảnh	Khôi phục đúng bí mật ban đầu; dùng 1 mảnh thì không khôi phục được

11	Giấu tin và phát hiện	Giấu một tệp vào ảnh, sau đó dùng chức năng phát hiện	Trích xuất đúng tệp; chức năng phát hiện ghi nhận dấu hiệu bất thường
12	Mô-đun siêu dữ liệu	Mở màn hình Xem siêu dữ liệu	Hiển thị thông báo không khả dụng và nút bị vô hiệu hoá (đúng thiết kế)
13	Tương thích liên nền tảng	Mở tệp kết tạo trên máy tính bằng ứng dụng di động	Mở được bằng đúng mật khẩu
14	Khoá phiên khi chuyển nền	Mở kết rồi chuyển ứng dụng sang chạy nền, quay lại	Ứng dụng yêu cầu nhập lại mật khẩu

Đề nghị ghi lại kết quả từng bước kèm ảnh chụp màn hình để bổ sung vào hồ sơ.

Phụ lục B. Hình ảnh cần bổ sung sau khi kiểm thử trên thiết bị thật

Các hình dưới đây chưa thể tạo trên máy chủ xây dựng vì cần thiết bị Android thật. Tác giả sẽ bổ sung sau khi thực hiện quy trình tại Phụ lục A. Hồ sơ chủ động để trống thay vì dùng ảnh mô phỏng, nhằm bảo đảm mọi hình ảnh trong hồ sơ đều là ảnh thật.

[CHỖ DÀNH CHO HÌNH — Hình PL-1]

Ảnh chụp màn hình ứng dụng đang chạy trên điện thoại Android thật (màn hình chính)

Hình PL-1 (tác giả bổ sung sau khi chạy trên thiết bị thật)

[CHỖ DÀNH CHO HÌNH — Hình PL-2]

Ảnh chụp mục Quyền ứng dụng trong Cài đặt hệ thống, cho thấy ứng dụng không có quyền truy cập mạng

Hình PL-2 (tác giả bổ sung sau khi chạy trên thiết bị thật)

[CHỖ DÀNH CHO HÌNH — Hình PL-3]

Ảnh chụp thao tác chọn tệp qua bộ chọn của hệ điều hành Android

Hình PL-3 (tác giả bổ sung sau khi chạy trên thiết bị thật)

....., ngày tháng năm 202...

XÁC NHẬN CỦA ĐƠN VỊ

(ký, ghi rõ họ tên, đóng dấu)

TÁC GIẢ SÁNG KIẾN

(ký, ghi rõ họ tên)